

Stage 6: Authentication & Session Management Specification

Executive Overview

Stage 6 delivers production-grade authentication, token rotation, account security, and session management for the Alight International Multi-Vendor Marketplace.

Key Features & Security Controls

1. Robust Password Cryptography

- Passwords are securely hashed using Spring Security's `BCryptPasswordEncoder` with salted key stretching.
- Minimum password length standard enforced across registration, password resets, and changes (min 8 characters).

2. Automated Account Lockout Protection

- **Lockout Threshold:** 5 consecutive failed login attempts.
- **Lockout Duration:** 15 minutes (`account_locked_until = now() + 15m`).
- **Counter Reset:** Automatic counter reset to 0 upon successful credential authentication or successful password reset.

3. JWT & Refresh Token Rotation

- **Stateless Access Tokens:** Embedded user identity, assigned roles, and granular permissions for instant RBAC authorization.
- **Opaque Single-Use Refresh Tokens:** Persisted in database, validated on renewal, and rotated immediately upon use (`is_revoked = true`).
- **Cross-Device Session Revocation:** When a password is changed or reset, all active refresh tokens for that user ID are invalidated immediately.

4. Password Recovery & Reset Flow

- Single-use, high-entropy tokens with 1-hour expiration window.
- Invalidation of previous active tokens on new request.
- Protection against user enumeration during forgot-password requests.

5. Email Verification Engine

- Single-use tokens with 24-hour validity window.
- Instant token consumption and audit trail.

- API endpoints for verification and resending verification tokens.

Schema Additions (`v32__auth_tokens_and_session_security.sql`)

1. **User Lockout Columns** (`users` table): - `failed_login_attempts INT NOT NULL DEFAULT 0` - `account_locked_until TIMESTAMP WITH TIME ZONE` - `last_login_at TIMESTAMP WITH TIME ZONE` 2. **password_reset_tokens** Table: - `id UUID PRIMARY KEY`, `user_id UUID REFERENCES users(id)`, `token VARCHAR(255) UNIQUE`, `expires_at TIMESTAMPTZ`, `is_used BOOLEAN` 3. **email_verification_tokens** Table: - `id UUID PRIMARY KEY`, `user_id UUID REFERENCES users(id)`, `token VARCHAR(255) UNIQUE`, `expires_at TIMESTAMPTZ`, `is_used BOOLEAN`

API Endpoints (`AuthController.java`)

Method	Endpoint	Description	Security
POST	<code>/api/v1/auth/register</code>	Register customer or vendor	Public
POST	<code>/api/v1/auth/login</code>	Authenticate with lockout protection	Public
POST	<code>/api/v1/auth/refresh-token</code>	Rotate refresh token	Public
POST	<code>/api/v1/auth/logout</code>	Revoke all active user sessions	Authenticated
GET	<code>/api/v1/auth/me</code>	Fetch active user profile & permissions	Authenticated
POST	<code>/api/v1/auth/forgot-password</code>	Request password reset token	Public
POST	<code>/api/v1/auth/reset-password</code>	Reset password using valid token	Public
POST	<code>/api/v1/auth/change-password</code>	Change password for current user	Authenticated
POST	<code>/api/v1/auth/verify-email</code>	Confirm email ownership	Public
POST	<code>/api/v1/auth/resend-verification</code>	Resend verification email token	Authenticated

Verification & Test Suite

- Comprehensive integration tests in `AuthenticationAndSessionIntegrationTest.java`.